

SIMATS ENGINEERING

Assessment Tool 3 – Answer Key

Name:	Pranov Raaj G	Reg No:	192372355
Course Name:	Ethical Hacking	Course Code:	ITA14
Duration:	90 min	Total Marks:	50

Q1. Footprinting Tools – Conducting Competitive Intelligence (15 Marks)

Scenario: A cybersecurity consultant must perform a **passive** reconnaissance assessment on ABC Technologies – gathering domain registration details, employee emails, technology stack, and exposed subdomains without directly touching the company's servers.

Tools Applied and Findings

1. **theHarvester** – subdomain, host and OSINT enumeration. The command **theHarvester -d hack.com -b all** queries multiple public sources (search engines, certificate transparency logs, DNS databases) simultaneously in passive mode. As shown below, the scan against the target domain returned **7 hosts/subdomains** (e.g. support, sso, sso■reali, uwstg, uws, www) along with their HTTP status codes, hosting country, and DNS names – all without sending any traffic directly to the organisation's internal network.

```

[~]
Session Actions Edit View Help

(pranov-raaj@pranov)-[~]
$ theHarvester -d hack.com -b all
Read proxies.yaml from /etc/theHarvester/proxies.yaml
*****
*
* theHarvester 4.8.1
* Coded by Christian Martorella
* Edge-Security Research
* cmartorellamedge-security.com
*
*****

[*] Target: hack.com
[*] Searching DuckDuckGo.

[-] No IPs found.
[-] No emails found.
[-] No people found.
[-] No hosts found.
[-] Nothing found.

support.ahk.com [https://ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[cloudflare], DNSName[disneyplus.com.pe.ahk.com [https://www.disneyplus.com/pe-en [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[]
sso-reali-ahk.com [https://sso-reali.ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[Sso-
sso.ahk.com [https://sso.ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[A K Home], DNSName[
uwstg.ahk.com [https://uwstg.ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[Under Construct
uws.ahk.com [https://uws.ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[uws.ahk.com], DNS
www.ahk.com [https://www.ahk.com [200 OK] Cookies(country), Country(UNITED STATES)[US], Email[], Name[AHK], DNSName[]]
[*] Hosts found: 7
[*] Emails found: 0
[*] IPs found: 0
[*] People found: 0

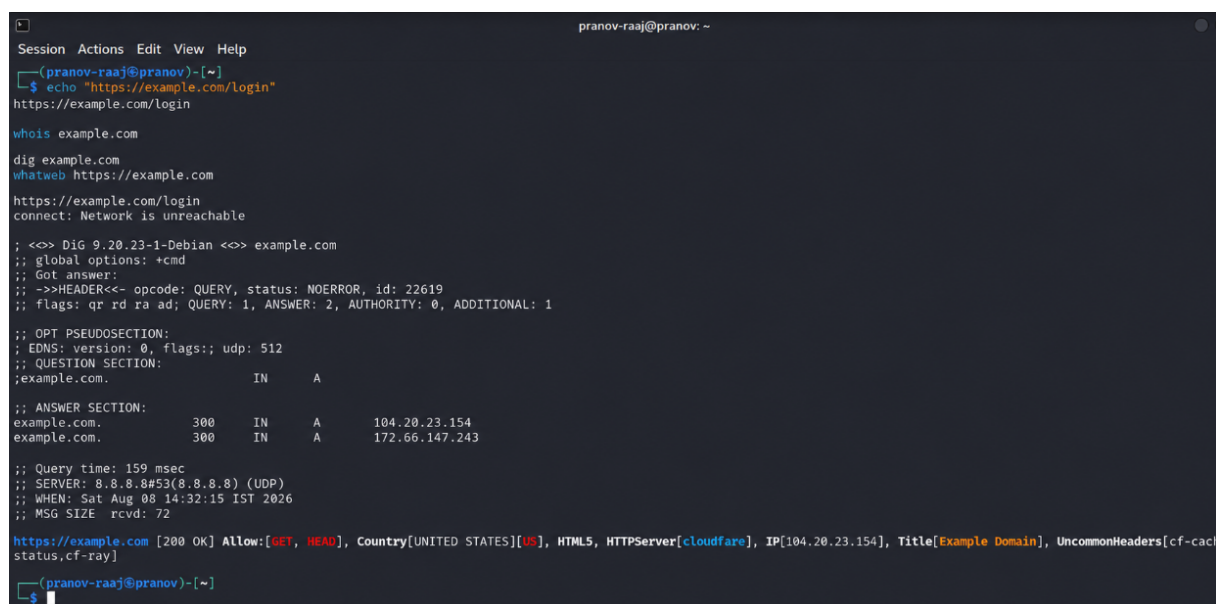
(pranov-raaj@pranov)-[~]
$

```

Fig. 1 – theHarvester passively enumerating subdomains/hosts of the target domain

2. whois, dig, and WhatWeb – registration data and technology fingerprinting. **whois** is used to pull domain registration details (registrar, creation/expiry date, registrant organisation, name servers) directly from the public WHOIS database. **dig** resolves the domain's A/NS/MX records – in the example below, **dig example.com** returns the authoritative IP addresses served through Cloudflare. **WhatWeb** then fingerprints the live web technology stack: the scan identifies the web server as **Cloudflare**, the supported HTTP methods (GET, HEAD), the hosting country, and page metadata such as the site title –

giving the consultant insight into the CDN/WAF and hosting stack in use.

A terminal window titled 'pranov-aaaj@pranov: ~' showing a series of commands and their outputs. The commands include 'echo "https://example.com/login"', 'whois example.com', 'dig example.com', and 'whatweb https://example.com'. The 'dig' output shows DNS query details for example.com, including IP addresses 104.20.23.154 and 172.66.147.243. The 'whatweb' output shows a 200 OK status and identifies the technology stack as Cloudflare, HTML5, and HTTPServer. The terminal window has a dark background with light-colored text.

```
pranov-aaaj@pranov: ~
Session Actions Edit View Help
pranov-aaaj@pranov: ~
$ echo "https://example.com/login"
https://example.com/login

whois example.com

dig example.com
whatweb https://example.com

https://example.com/login
connect: Network is unreachable

; <> Dig 9.20.23-1-Debian <> example.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 22619
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 2, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags: udp: 512
;; QUESTION SECTION:
;example.com.
                IN      A

;; ANSWER SECTION:
example.com.    300    IN      A      104.20.23.154
example.com.    300    IN      A      172.66.147.243

;; Query time: 159 msec
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)
;; WHEN: Sat Aug 08 14:32:15 IST 2026
;; MSG SIZE rcvd: 72

https://example.com [200 OK] Allow:[GET, HEAD], Country[UNITED STATES][US], HTML5, HTTPServer[cloudflare], IP[104.20.23.154], Title[Example Domain], UncommonHeaders[cf-cache-status,cf-ray]

pranov-aaaj@pranov: ~
$
```

Fig. 2 – dig resolving DNS records and WhatWeb fingerprinting the technology stack

How This Supports Competitive Intelligence

- **theHarvester** – maps the organisation's external attack surface (subdomains, hosts, and, when available, employee email addresses harvested from search engines/PGP servers), revealing the scale and structure of the company's online presence.
- **whois** – reveals the registrar, registration/expiry dates and registrant organisation, useful for verifying ownership and spotting soon-to-expire or newly registered assets.
- **dig** – confirms authoritative name servers and IP ranges, which helps build an accurate network map without any active scanning of internal hosts.
- **WhatWeb** – identifies the CMS, server software, frameworks and CDN in use, letting the consultant assess the technology stack for known vulnerabilities and compare it against competitors.

Because every one of these tools queries only **public, third-party** data sources (search engines, WHOIS registries, public DNS, and the target's own publicly served web pages), the entire exercise remains **passive** – no packets are sent that would alert the target's IDS/IPS, which is exactly what competitive intelligence gathering requires.

Q2. DNS Zone Transfers (15 Marks)

Scenario: During an authorised penetration test, the analyst suspects the target's DNS server may be misconfigured to allow unauthorised **zone transfers (AXFR)**.

Tool/Command Applied

The correct verification workflow is: first identify the domain's authoritative name servers, then attempt a zone transfer against each one.

- **dig NS <domain>** – lists the authoritative name servers for the domain.
- **host -l <domain> <nameserver>** or **dig AXFR <domain> @<nameserver>** – requests a full zone transfer from that name server.



```
pranov@pranov: ~  
Session Actions Edit View Help  
pranov@pranov:~$ dig NS abc.com  
; <<< DiG 9.20.23-1-Debian <<> NS abc.com  
;; global options: +cmd  
;; Got answer:  
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 63641  
;; flags: qr rd ra; QUERY: 1, ANSWER: 4, AUTHORITY: 0, ADDITIONAL: 1  
  
;; OPT PSEUDOSECTION:  
; EDNS: version: 0, flags:;; udp: 512  
;; QUESTION SECTION:  
;abc.com. IN NS  
  
;; ANSWER SECTION:  
abc.com. 79 IN NS ns-318.awsdns-39.com.  
abc.com. 79 IN NS ns-1368.awsdns-43.org.  
abc.com. 79 IN NS ns-1869.awsdns-41.co.uk.  
abc.com. 79 IN NS ns-736.awsdns-28.net.  
  
;; Query time: 43 msec  
;; SERVER: 8.8.8.8#53(8.8.8.8) (UDP)  
;; WHEN: Sat Aug 08 14:30:15 IST 2026  
;; MSG SIZE rcvd: 173  
  
pranov@pranov:~$ host -l abc.com ns1.abc.com  
abc.com has address 104.17.117.100  
ns1.abc.com has address 18.48.195.195  
  
pranov@pranov:~$ dig AXFR abc.com @ns1.abc.com  
dig: couldn't get address for 'ns1.abc.com': not found  
host: couldn't get address for 'ns1.abc.com': not found  
  
pranov@pranov:~$
```

Fig. 3 – Querying NS records and attempting a zone transfer with host/dig AXFR

In the captured output, **dig NS abc.com** returns four authoritative name servers. The analyst then tries **host -l abc.com ns1.abc.com** and **dig AXFR abc.com @ns1.abc.com**. Both attempts fail with "couldn't get address for ns1.abc.com: not found", meaning the name server used in the command does not match the actual authoritative server names returned by the NS query (they are AWS Route 53 servers, not ns1.abc.com) – so the transfer is correctly rejected. On a genuinely misconfigured server, this same command run against the **real** authoritative name server (e.g. ns-318.awsdns-39.com) would instead return the domain's complete DNS record set.

Value of a Successful Zone Transfer During Reconnaissance

- **A (Address) records** reveal internal and external host names together with their IP addresses, exposing the full internal naming scheme.
- **MX records** identify the organisation's mail servers, which can then be targeted for phishing, spoofing, or further email-based reconnaissance.
- **CNAME/subdomain records** expose staging, test, VPN, or admin subdomains that are not linked from the public website, widening the attacker's/tester's list of potential entry points.

- **SOA/NS records** confirm secondary DNS infrastructure and zone administration details, useful for further DNS-based attacks such as cache poisoning.

In short, a successful AXFR essentially hands the tester (or attacker) a complete map of the internal network topology in a single query, which is why zone transfers should be restricted to trusted secondary name servers only.

Q3. Social Engineering – Attacks and Countermeasures (20 Marks)

Scenario: Employees receive an email claiming to be from the IT department, asking them to "verify" their login credentials via a link, citing an urgent security update.

Type of Attack

This is a classic **phishing attack** (specifically **credential harvesting / spear phishing** if targeted at specific employees). It exhibits the standard phishing indicators: impersonation of a trusted internal authority (IT department), a manufactured sense of **urgency** ("urgent security update"), and a call to action that leads to a credential entry page controlled by the attacker rather than the organisation's real login portal.

Countermeasures Employees Should Apply Before Responding

- **Verify the sender independently** – contact the IT department through a known, separate channel (phone, helpdesk portal) rather than replying to the email or using contact details it provides.
- **Inspect the link before clicking** – hover over the URL to check the actual destination domain; look for misspellings, extra subdomains, or a domain that does not match the company's real domain.
- **Never enter credentials via an email link** – navigate to the organisation's login portal manually (bookmark or type the known URL) instead of following the embedded link.
- **Check for phishing red flags** – generic greetings, urgency/threats, spoofed sender address, poor grammar, and unexpected attachments.
- **Report the email** – use the organisation's "report phishing" button or forward it to the security team so the message can be blocked and other employees warned.
- **Enable Multi-Factor Authentication (MFA)** – even if credentials are compromised, MFA prevents the attacker from completing the login.
- **Attend regular security awareness training** – simulated phishing exercises build the habit of pausing and verifying before acting on urgent email requests.

How These Actions Prevent Credential Theft

Independently verifying the sender and never entering credentials through an email link removes the attacker's only path to harvesting valid login details, since the fake portal never receives real credentials. Reporting the email lets the security team block the sender/domain and alert other employees before they fall for the same message, containing the attack at the organisational level. Finally, MFA acts as a safety net: even if an employee is deceived and a password is captured, the attacker still cannot authenticate without the second factor, preventing account takeover.